Users, Groups and Least Privilege

Project: *Okta Identity Lab |* ***Author:*** *Ismayeel Khan |* ***Date:*** *October 23, 2026 |* ***Environment:*** *Okta Integrator Free Plan*

---

1. Goal

The goal of this checkpoint was to build the "company" inside Okta: groups, users, and a helpdesk admin who has only the access the job needs.

2. The Plan

The free plan allows only **10 active users**, so I planned every account before creating any of them. That way I would not run out of slots.

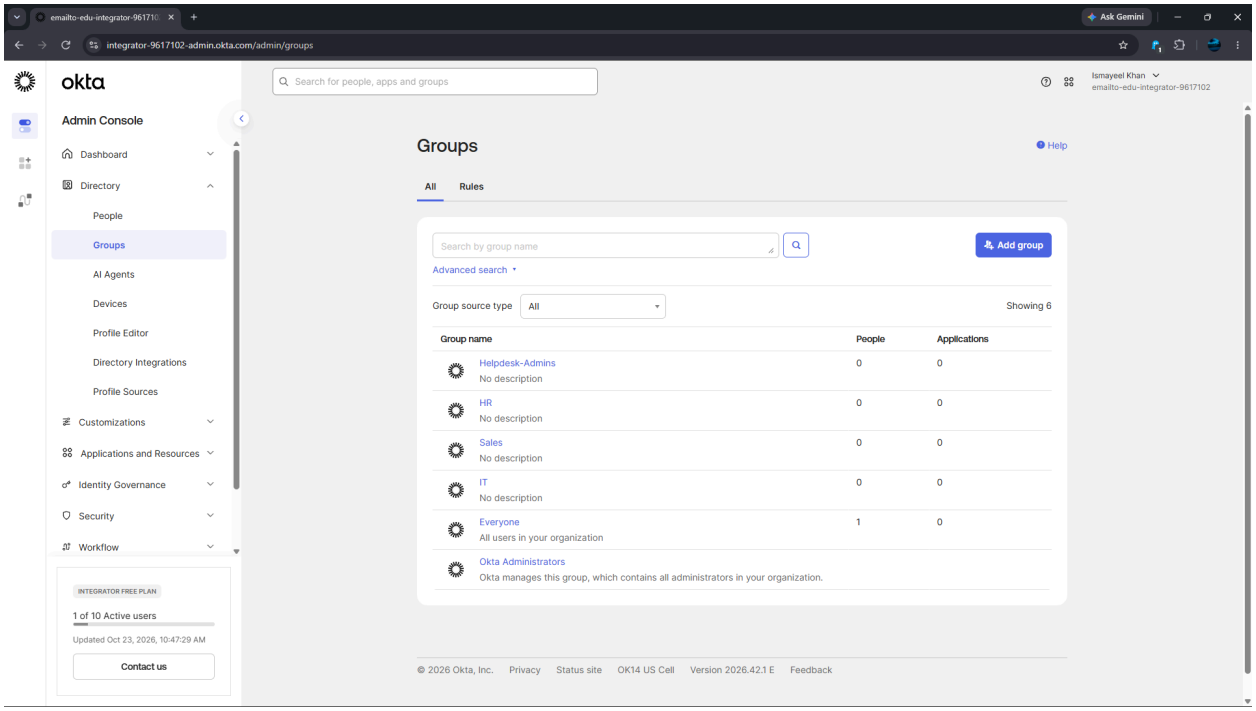
#	Name	Department	Role
1	Ismayeel Khan (me)	Admin	Super Administrator
2	Hana Desk	IT	Help Desk Administrator
3	Rohan Mehta	IT	IT Support Engineer
4	Meera Joshi	IT	Systems Analyst
5	Priya Sharma	HR	HR Manager
6	Aman Verma	HR	HR Executive
7	Neha Singh	Sales	Sales Manager
8	Karan Patel	Sales	Sales Rep
9	Sara Ali	Sales	Sales Rep
10	Dev Gupta	Sales	Sales Rep

All names, emails, and accounts in this lab are fake and exist only for testing.

3. Creating the Groups First

I created the groups before the users so I could place each person in the right group while creating their account. I made four groups:

- **IT**
- **HR**
- **Sales**
- **Helpdesk-Admins**



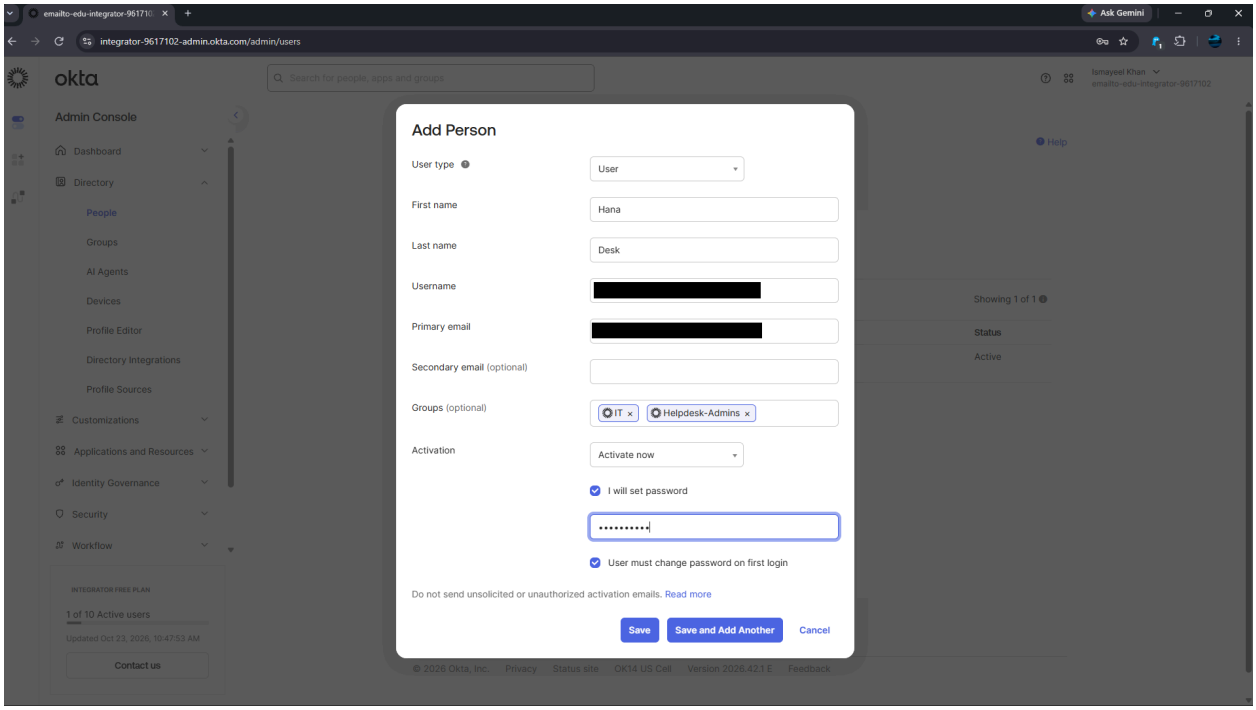
Groups list after creating IT, HR, Sales, and Helpdesk-Admins. They are empty at this point.

Why groups matter: in real companies, access is given to groups, not to individual people. When someone joins, moves, or leaves, you change their group and their access changes with it. It works the same way as security groups in Active Directory.

4. Creating the Users

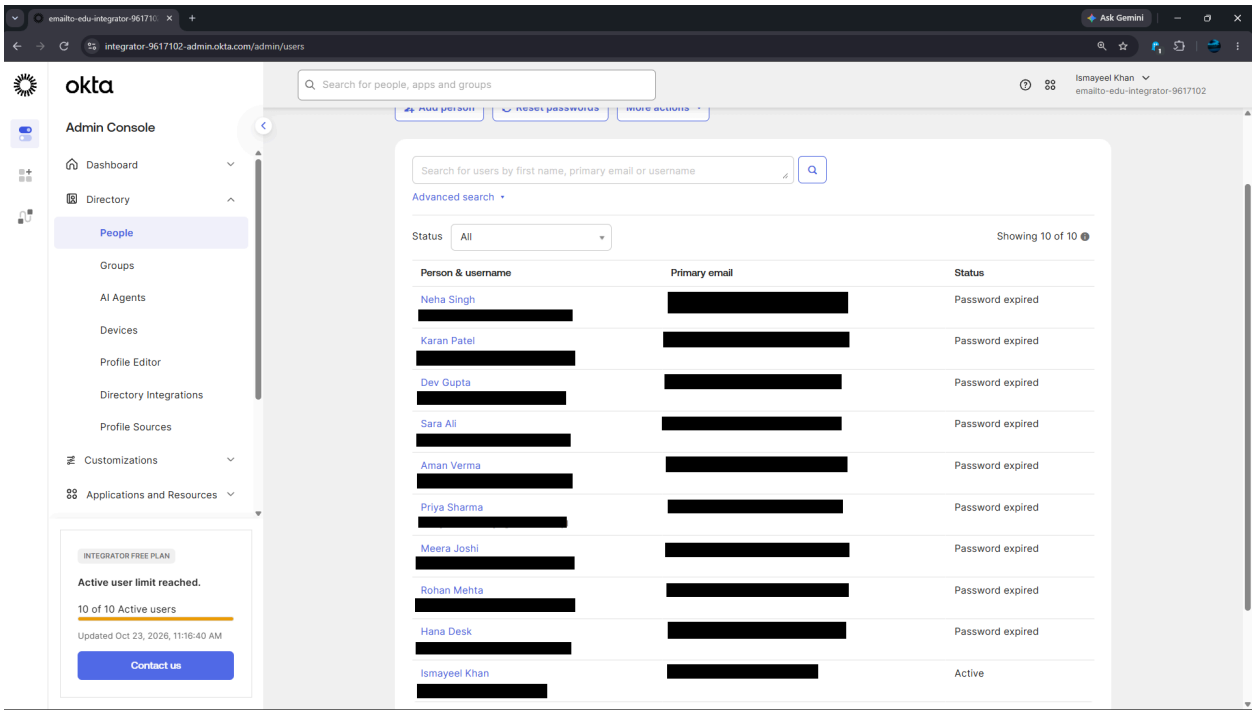
I added each user from **Directory > People > Add person**. For each one I filled in the name, username, and primary email, chose their department group, and set a temporary password.

For every user I ticked **"User must change password on first login."** This is how real onboarding works: the admin never knows the user's final password.



Add Person form for the helpdesk account, with the groups chosen and a forced password change turned on.

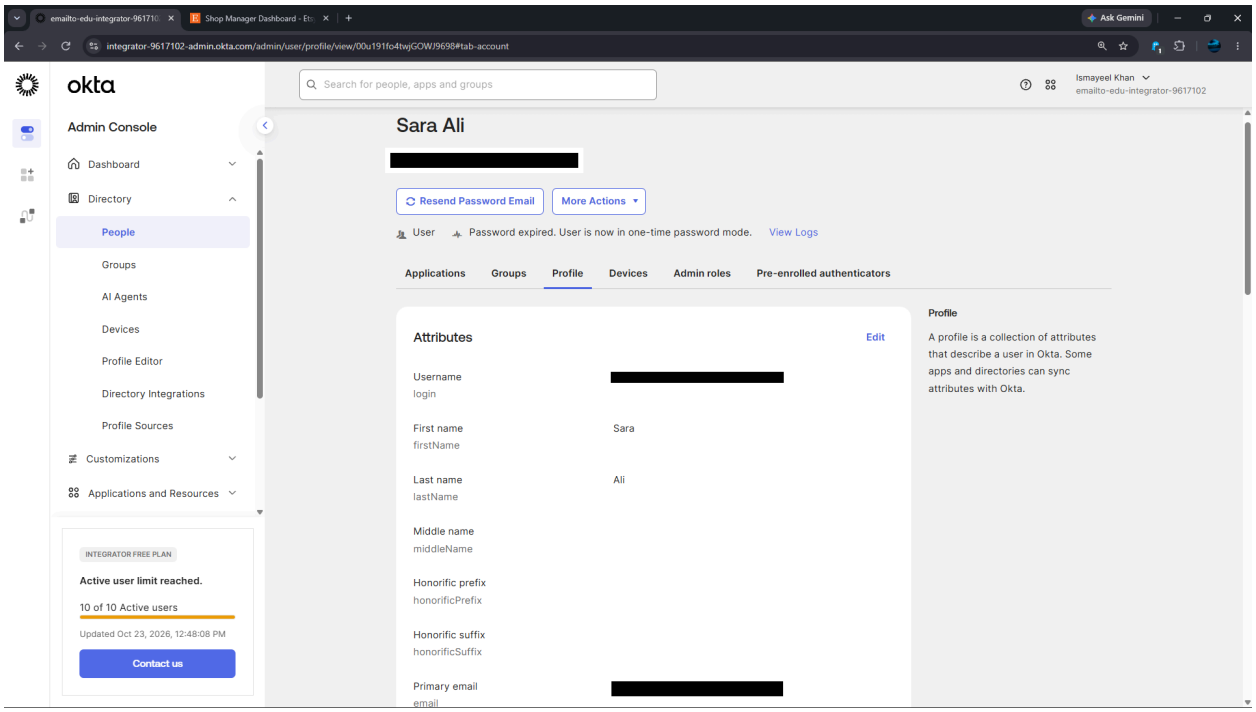
After creating all the accounts, the People list showed 10 users. Everyone except me had the status **Password expired**. That is expected: it means the account is waiting for the user's first sign-in, when they must set a new password.



People list with all 10 users. New users show "Password expired" until their first login.

Filling in the profile details

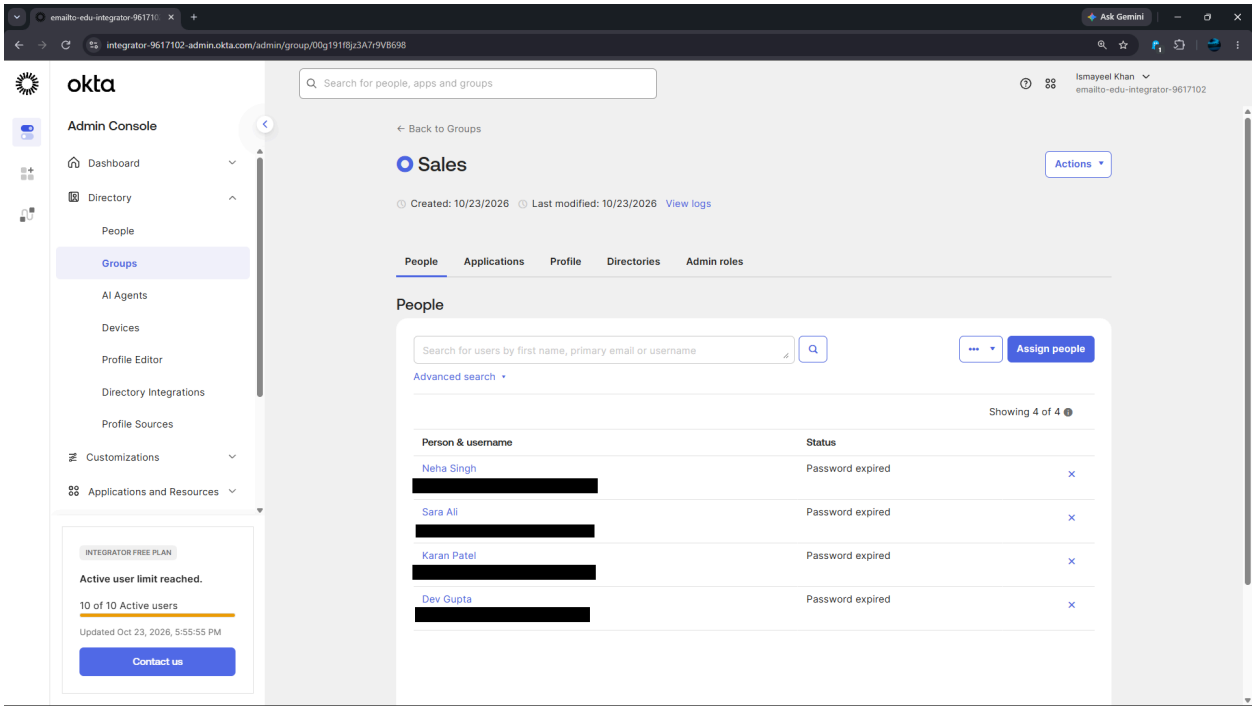
I then opened each user's profile and added their **department** and **title**. These fields matter because real companies use them later to automate access.



Example user profile (Sara Ali) with her attributes.

5. Checking Group Membership

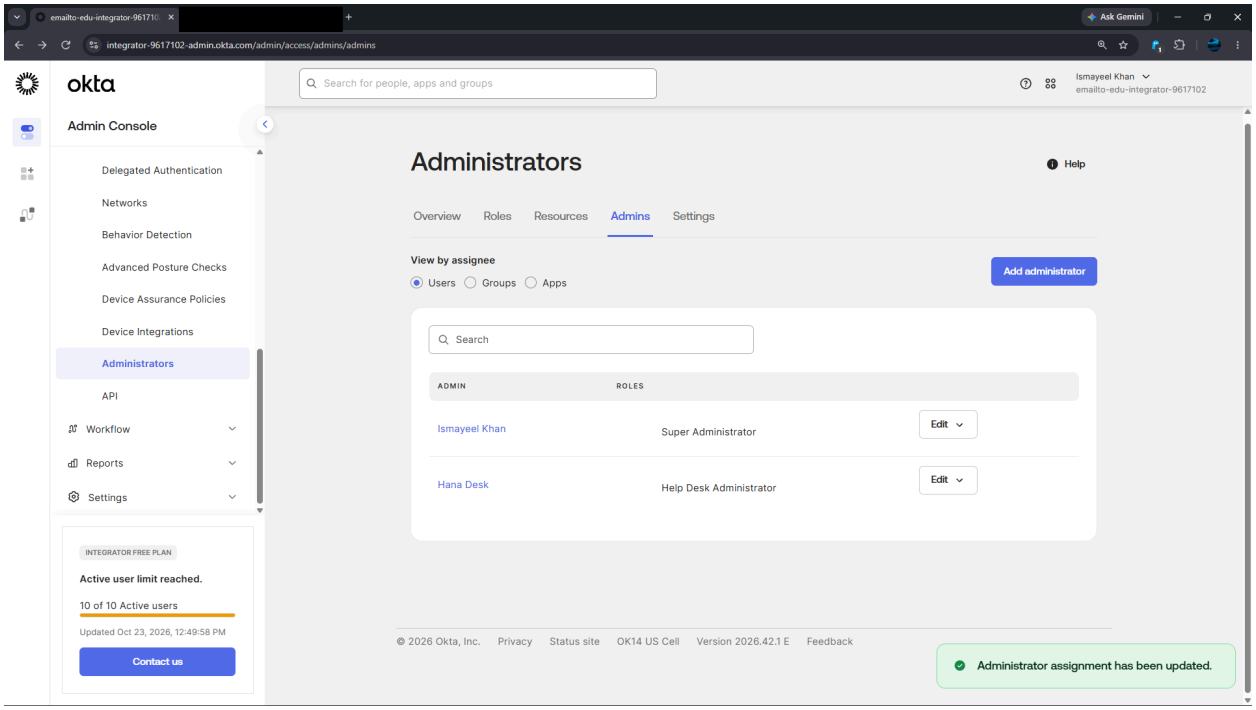
After creating everyone, I opened each group to confirm the right people were in it. The Sales group, which was my biggest, had four members.



Sales group members.

6. The Helpdesk Admin and Least Privilege

The last step was to give the helpdesk account an admin role. I did not make her a Super Administrator. I gave her the **Help Desk Administrator** role, which allows daily support tasks such as resetting passwords and unlocking accounts, but does not allow changing company-wide security settings.



Administrators page with two admins and two different roles: Super Administrator (me) and Help Desk Administrator (Hana Desk).

This is called **least privilege**: every person gets only the access they need to do their job. If the helpdesk account were ever compromised, the damage would be much smaller than if it were a super admin.

How this account was used in the support tickets is covered in Document 6.

7. Problems I Ran Into

- **Usernames must look like an email address.** I wanted a short username such as "Hdesk", but Okta's default rule requires an email format. Instead of changing the rule, I used the same address for username and primary email, which is also how real companies usually do it.
- **Every user needs a different email.** I used plus addressing (for example, name+hana@...) so each user had a unique address while all messages reached one inbox.
- **The user counter lagged behind.** After creating the users, the counter still showed "1 of 10" for a few minutes. It only updates after a delay, so I refreshed it later and it showed "10 of 10."

8. Key Concepts I Learned

- **Groups:** assign access to a group, not to one person at a time.
- **Least privilege:** give each role only the access it needs.
- **Forced password change:** new users set their own password at first login.
- **User status:** "Password expired" on a new account is normal until the first sign-in.
- **Profile attributes:** fields like department and title can be used later to automate access.

9. Limits and Notes

- The free plan allows **10 active users**, so the lab is built around exactly 10 accounts.
- All data is fake. No real personal information was used.

10. What I Learned and What Is Next

The main lesson from this checkpoint: **give access to groups, and give admins only the permissions they need.**

Next, in Checkpoint 3, I connect apps to Okta and test single sign-on, including who gets in and who gets blocked.